Security Scan Report

Automated Web Security Scanner v1.0 • Scanned at (UTC): 2026-10-20T19:14:28.528431+00:00

Target	`http://127.0.0.1:8080/secure`
Final URL	`http://127.0.0.1:8080/secure`
HTTP Status	`200`
Response Time	21.85 ms

7	0	0
TOTAL FINDINGS	HIGH	MEDIUM

0	7
LOW	INFO / PRESENT

Inspection Findings & Recommendations

INFO **Content Security Policy (CSP)** PRESENT

Check: `content-security-policy`

Observed Evidence:

```
content-security-policy: default-src 'self'; script-src 'self'; object-src 'none';
```

> **Remediation Guidance:**
> Review the policy for correctness and compatibility; presence alone does not guarantee a safe configuration.

INFO **HTTP Strict Transport Security (HSTS)** NOT_APPLICABLE

Check: `strict-transport-security`

Observed Evidence:

```
Final response URL is not HTTPS.
```

> **Remediation Guidance:**
> HSTS is delivered over HTTPS; configure HTTPS first, then review HSTS.

INFO **X-Content-Type-Options** PRESENT

Check: `x-content-type-options`

Observed Evidence:

```
x-content-type-options: nosniff
```

> **Remediation Guidance:**
> Review the policy for correctness and compatibility; presence alone does not guarantee a safe configuration.

INFO **Referrer-Policy** PRESENT

Check: `referrer-policy`

Observed Evidence:

```
referrer-policy: strict-origin-when-cross-origin
```

> **Remediation Guidance:**
> Review the policy for correctness and compatibility; presence alone does not guarantee a safe configuration.

INFO **Permissions-Policy** PRESENT

Check: `permissions-policy`

Observed Evidence:

```
permissions-policy: geolocation=(), camera=(), microphone=()
```

Remediation Guidance:

Review the policy for correctness and compatibility; presence alone does not guarantee a safe configuration.

INFO **Framing protection** PRESENT

Check: `clickjacking_protection`

Observed Evidence:

```
X-Frame-Options or CSP frame-ancestors was observed.
```

Remediation Guidance:

Confirm the framing policy matches the site's intended embedding behavior.

INFO **CORS configuration** OBSERVED

Check: `cors`

Observed Evidence:

```
Access-Control-Allow-Origin: https://trusted.example.com
```

Remediation Guidance:

Compare the allowed origin against the application's intended allowlist.

Scope & Limitations:

- Only one GET request and one OPTIONS request are sent; this is not a crawler.
- The scanner does not test authentication, authorization, application logic, injection, or exploitability.
- Header presence is not proof that a policy is correctly configured.
- CORS behavior may vary by endpoint and request; manual review is required.
- Run only against systems you own or have explicit permission to assess.